The Journal of Supercomputing (2021) 77:1114–1151
https://doi.org/10.1007/s11227-020-03318-7

# A lightweight remote user authentication scheme for IoT communication using elliptic curve cryptography

**Dipanwita Sadhukhan[1] · Sangram Ray[1] · G. P. Biswas[2] · M. K. Khan[3] · Mou Dasgupta[4]**

Published online: 7 May 2020
© Springer Science+Business Media, LLC, part of Springer Nature 2020

**Abstract**
Internet of things (IoT) has become a new era of communication technology for performing information exchange. With the immense increment of usage of smart devices, IoT services become more accessible. To perform secure transmission of data between IoT network and remote user, mutual authentication, and session key negotiation play a key role. In this research, we have proposed an ECC-based three-factor remote user authentication scheme that runs in the smart device and preserves privacy, and data confidentiality of the communicating user. To support our claim, multiple cryptographic attacks are analyzed and found that the proposed scheme is not vulnerable to those attacks. Finally, the computation and communication overheads of the proposed scheme are compared with other existing protocols to confirm that the proposed scheme is lightweight. A formal security analysis using AVISPA simulation tool has been done that confirms the proposed scheme is robust against relevant security threats.

**Keywords** Elliptic curve cryptography (ECC) · Elliptic curve Diffie–Helmen (ECDH) · Internet of things (IoT) · Remote user authentication · Three-factor authentication

## 1 Introduction

Internet of Things (IoT) framework is a wide collection of low-power-consuming sensor nodes which are geographically dispersed to each other to form an intelligent, autonomous ad hoc network that can be installed in any unfamiliar environment to collect data from their surroundings. Its application includes remote environments such as military battle field surveillance, smart homes, healthcare, wildlife tracking, smart cities, environment monitoring, intelligent agriculture, traffic management,

✉ Sangram Ray
sangram.ism@gmail.com

Extended author information available on the last page of the article

etc. [1–3]. Initially, the term 'Internet of Things' was used by Kevin Ashton, one of the founders of MIT Auto–ID Centre, in 2001 [4]. The 'Things' in IoT scenario has become the future of Internet for its low-cost communication through various wireless techniques. IoT nodes are basically multifunctional and self-organizing in nature, and can sense, monitor, collect, and compile information from remote areas. Further, the data can be processed, analyzed, or integrated to generate meaningful information.

### 1.1 Security issues of IoT

The main features of IoT are interoperability, dynamicity and heterogeneity. So, IoT network always needs to interact with uncertain conditions thus has to face various security challenges [4]. Users' smart devices often store much vital information about the user, device, network and security parameters, etc. Since any user-centric application preserves user's identity and credentials, the protection from information leakage becomes crucial. So that the attackers cannot be able to track the stored information from the running applications or hack the original identity of the user/device for any infringed use. Here, two aspects can be considered—(1) only the authenticated user can communicate with the IoT network to collect the desired data and (2) only the legitimate node can transfer data to the user [5]. Hence, the most important challenges required to be fulfilled for a secure communication between the IoT environment and the user, are as follows [4]:

- *Identity requirement* Identities of the IoT system and the user should be verified.
- *Privacy requirement* Importance of preserving the confidentiality of data exchanged between the IoT system and user.
- *Trust requirement* Importance of managing the trust, the main goal of the IoT environment, between the sender and receiver [6].

To incorporate these challenges, the requirement of remote user mutual authentication between the IoT network and the user is realized. Mutual authentication guarantees that both the sender and receiver are legitimate and exchange messages within the pre-negotiated session [7, 8]. In this aspect, different security measures should be applied like encryption, authentication, dynamic key management, identity, and biometric-based authentication, etc. It is very essential for a remote sensing environment to maintain following significant factors to gain users confidence [9–11]:

- *Data protection* It should be maintained as a fundamental issue in IoT network since IoT always deals with the data mining and data analysis.
- *Identity and privacy preservation* User always provides his/her secret information in IoT network. So protecting them is the most important issue.
- *Transmission and communication trust* Huge amount of data is transmitted over a channel that may be noisy, duplicated and conflicting in nature. These factors may affect the reliability of the provided information. Data Perception Trust

(DPT), Communication Trust (CT), and Data fusion Trust (DFT) are the major dimensions that are revealed in the data reliability and reliability [12].

### 1.2 Literature review

With the constant progress of IoT paradigm, several surveys and novel research works have been done over continuous improvement in respect of the various efficiency and security issues faced by IoT system. A brief review of them is discussed here.

In 2010, Atzori et al. [7], Weber [13] and Gubbi et al. [14] have prepared survey over various complex scenarios of an IoT network. In their work, different IoT paradigm enabling technologies are presented and reviewed to discover several privacy and security issues of IoT network. However, authors did not provide any security solution for those issues. Later on, a comprehensive study on the trust management for IoT network has been conducted by Chang et al. [15] and Yan et al. [16] in 2013. According to the authors of [14], trust management plays an important role in data fusion and data mining for context-oriented enhancement in user privacy and information protection. Trust management provides confidence in reliability, accuracy and timeliness in information transmission [16].

Toward solving several technical issues related to efficiency and security, Xue et al. [17] have proposed five models for mutual authentication for wireless sensor network having three types of participants—user, gateway, and sensor nodes. Each model needs total four messages exchange among three participants to complete the mutual authentication. Authors have also proposed a mutual authentication and key negotiation scheme based on temporal credential of the remote user where the credentials can be firmly accumulated in a smart card. In the scheme of Xue et al. [17], only XOR and hash operations are used to reduce computation overhead as well as provide security. However, according to Wang et al. [18] the major drawback of the two-factor password-based authentication scheme is that anyone can impersonate any legitimate user [18]. Moreover, the scheme does not include the password changing procedure to allow users periodically update their password. Furthermore, Jiang et al. [8] in 2015, has pointed out that this scheme cannot withstand offline password-guessing attack, identity guessing attack and user tracking attack. Sood et al. [19] proved that the scheme [17] is vulnerable to dictionary forgery and user impersonation attack and proposed an enhanced authentication protocol. Song et al. [20] demonstrated that the scheme [19] is insecure to forgery and server impersonation attack. Later, Chen et al. [21] have done cryptanalysis of the scheme of Sood et al. [19]. They [21] discovered that Sood et al's scheme [19] does not satisfy proper mutual authentication as the remote user never validate the authenticity of the server. They [21] also proposed a novel authentication scheme which is later proven inefficient and is vulnerable to impersonation or insider attack by Kumari and Khan [22]. Li et al. showed that the scheme [21] failed to satisfy perfect forward secrecy. Jiang et al. [8] have demonstrated that Chen et al. [21] scheme is suffering from password-guessing attack. Besides, Jiang et al. [8] proposed an improved scheme which eradicates the limitation of Chen et al.'s scheme [21]. However, Mishra et al.

[23] proved that the scheme of Jiang et al.'s [8] does not fully overcome the found shortcomings and is insecure to password-guessing attack, forgery attack, and also proposed a password-based authentication and key agreement protocol. However, according to Sharma and Karla [24] the scheme [23] is vulnerable to server spoofing attack, offline password-guessing attack, and hidden server attack.

In 2014, Porambage et al. [25] and Turkanovic et al. [26] have proposed novel authentication schemes for heterogeneous networks like ad hoc wireless sensor network. Poorambage et al. [25] proposed a scheme where sensor node and user can mutually authenticate themselves without the requirement of gateway that makes it suitable for resource-constrained sensing networks. However, the scheme bears various security flaws like man-in-the-middle attack, denial-of-service attack, privileged insider attack, replay attack, etc [9]. The scheme of Turkanovic et al. [26] has demonstrated a remote user authentication as well as a key agreement protocol using hash and XOR operation for mutual authentication among the remote users and dynamic sensor nodes in IoT network. Later, Amin and Biswas [27] in their recent work have established that this scheme is subject to some damaging security attacks: user impersonation attack, identity guessing attack etc.

In the meantime, Karla and Sood [28] have proposed elliptic curve cryptography (ECC) based secure authentication schemes for embedded devices which act as HTTP clients in 2015. They have focused on data privacy and authentication, the two most essential features for IoT paradigm. However, Kumari and Karuppiah [29] has demonstrated that the scheme [28] suffers from offline password-guessing and insider attacks along with this the scheme does not achieve anonymity, mutual authentication and session key agreement.

Later on, in 2016 Cheng and Le [30] have proposed a smart card-based two-factor authentication protocol using ECC that offers an extremely lightweight solution for WSN. Unfortunately, Das et al. [10] identified that the scheme is vulnerable to offline password-guessing attack and session-specific temporary information attack. However, Kumari et al. [11] demonstrated that the three-factor-based scheme proposed by Das et al. [10] in 2016 cannot withstand stolen verifier attack, impersonation attack and stolen smart card attack.

In 2017 Dhillon and Karla [31] have worked on the most crucial security issues of IoT paradigm, secure access of the IoT services and proposed a three-factor-based lightweight remote user mutual authentication scheme between the user and the sensor node without intervention of the gateway. However, this scheme is subject to security breaches: High verification time and memory consumption [32]. It does not allow dynamic addition of IoT nodes.

Challa et al. [33] in 2017 also proposed a signature-based authentication and key agreement scheme for IoT environment using ECC-based digital signature. This scheme provides user anonymity and untraceability. Yet, Wazid et al [9] in 2018 shows it incurs high computation cost compared to other related schemes. Additionally, Wazid et al have proposed a novel secure remote user authentication scheme for generic IoT environment. According to Fakroon et al. [34] the scheme [9] is inefficient for resource-constrained networks as the scheme only operates on the one-way hash function and XOR operation. Moreover, the scheme stores a verification table based on gateway database. If the table is stolen, the consequences must be fatal

[34]. In the same year, Sharma and Karla [24] have proposed a remote user authentication scheme for IoT- Cloud environment. However, the scheme of Sharma and Karla [24] does not achieve clock synchronization and timely typo detection [35]. In 2019, Shuai et al. [36] proposed a remote authentication scheme for smart home environment using ECC. However, Fakroon et al [34] in 2020 shows that the scheme suffers from insufficient performance in terms of computational and communication costs and also suffers from parallel session attack, privileged insider attack. Recently, in 2020 Wang et al. [18] have tried to inspect some significant multi-factor authentication schemes, emphasize commonly repeated flaws in previous multi-factor schemes for multi-server environments and detect some new challenges to design any sound multi-factor schemes for multi-server environments.

### 1.3 Motivation and our contribution

It can be concluded from the above discussion that most of the existing user authentication and key agreement schemes of IoT network are not completely protected against possible security breaches. Moreover, some schemes are not efficient in terms of computational and communication overheads for resource-constrained devices. In this scenario, there exists a considerable need of a secure lightweight remote user authentication and key agreement scheme. This motivates us to propose a standardized proficient, secure, inexpensive and robust mutual authentication scheme for IoT paradigm to fix the limitations discussed in the above literature. The contribution of the research work is as follows:

- Towards considering the several security issues such as data confidentiality, integrity, authentication etc. and minimizing the associated computation and communication overheads, we propose elliptic curve cryptography (ECC) based remote user mutual authentication scheme for IoT environment that establishes a three-factor authentication between the remote user and the gateway, as well as between the gateway and sensor node.
- We prove the security strength of our proposed protocol using two different approaches: informal security analysis and the formal AVISPA simulation tool.
- We compare our scheme with other related schemes; the comparison results exhibit that our scheme is advanced to the existing schemes in terms of security and performance.

### 1.4 Organization of the paper

The rest of the paper is organized as stated below: Sect. 2 presents the basic idea about ECC and its various operations and computational problems. In Sect. 3, the proposed scheme using ECC is described. The security analysis against various attacks and the performance analysis comparing with other existing schemes in terms of computational overhead and effectiveness are discussed in Sects. 4 and 5. In Sect. 6, the simulation result of the proposed scheme by means of well-known

AVISPA simulation tool is discussed that proofs the formal security verification of the scheme and finally Sect. 7 draws the conclusion of the paper.

## 2 Overview of elliptic curve cryptography

Elliptic curve cryptography (ECC) is one of the most secure and efficient public key cryptosystem and has become a standardized, substantial and cost-effective in terms of computation and communication in modern cryptography [27, 37, 38]. In 1985, ECC was initially proposed by Neal Koblitz [39] and Victor Miller [40]. Recently ECC has received commercial acceptance and inclusion in the security products of various standard organizations. [27].

### 2.1 Definition

The elliptic curve $E/F_q$ over a prime finite field $F_q$ is the set of all points $(x, y) \in F_q$ and is defined by the non-singular elliptic curve equation:

$$y^2 mod\, q\left(x^3 + ax + b\right) mod\, q \tag{1}$$

where $(a, b) \in F_q$, the discriminant $D = \left(4a^3 + 27b^2\right) mod\ q \neq 0$ *and* $G_q = \{(x, y) : x, y \in Fq\}$ and $(x, y) \in E/F_q\} \cup \{O\}$ defines elliptic curve additive group where $O$ is called *point at infinity.*

### 2.2 Group operations

- *Point addition* Any two points such as $P$, $Q$ lie on the elliptic curve in Eq. 1 such that $P+Q=R$, then the line connecting $P$ and $Q$ intersects the curve at $-R$, the reflection of $R$ with respect to *x-axis* [41, 42].
- *Point of subtraction* Let, $P$, $Q$ be the points on the elliptic curve in Eq. 1, where $P=-Q$, and $P+P=P-P=O$ then, the intersecting line of the curve and the points $P$ and $Q$ joins at an abstract point $O$ (*point of infinity*) [43, 44].
- *Point doubling* Addition of a point $P$ on the curve in Eq. 1 with the same point to get a point $Q$ on the same curve such that $2P=Q$ where, $Q$ is the point of reflection with respect to *x-axis* of the point of intersection of the tangent line at $P$. [45]
- *Scalar point multiplication* For elliptic curve $t.P = P + P + \cdots + P$ (t times) $=\sum_1^n P$, where $t \in \mathbb{Z}_q^*$and $t$ is a scalar number in the cyclic group $G_q$. [46]
- *Order of Point* The order of point is defined in a cyclic elliptic group is $n.P=O$ (point of infinity) where $n>0$ is an integer [45].

To solve the computational problems of elliptic curve cryptosystem such as ECDLP reveals the security hardness of ECC [41–47]. Some of the computational

problems on ECC are discussed below that does not have any polynomial time solution.

### 2.3 Computational problems

- *Elliptic curve discreet logarithm problem* (*ECDLP*) Given that $P, Q \in G_q$ and $k \in \mathbb{Z}_q^*$ such that $Q = k.P$. It is hard to find $k$ from $Q$ in polynomial time [46, 47].
- *Computational Diffi–Helmen Problem* (*CDHP*) Computation of $abP$ is difficult for any random instances $a$, $b$ and $P$ where $(P, aP, bP) \in E/F_q$ and $a, b \in \mathbb{Z}_q^*$ is hard [27].
- *Elliptic curve factorization problem* (*ECFP*) Computation of $aP$ and $bP$ is impossible in polynomial time such that $P, Q \in G_q$ and $Q = aP + bP$ where $a, b \in \mathbb{Z}_q^*$ [48].
- *Decisional Diffi–Helmen Problem* (*DDHP*) Given $(P, aP, bP) \in G_q$ for any $a, b, c \in \mathbb{Z}_q^*$ it is impossible to decide whether $c.P = ab.P$, *i.e.*, $C = ab \bmod q$ or not [48].

### 2.4 ECC-based certificate

PKIX.X.509, includes user's identity and an ECC-based public key of the user together that is signed by the certificate authority using ECDSA [45]. An ECC-based X.509 certificate format which is proposed by ITU is given in Fig. 1 [43].

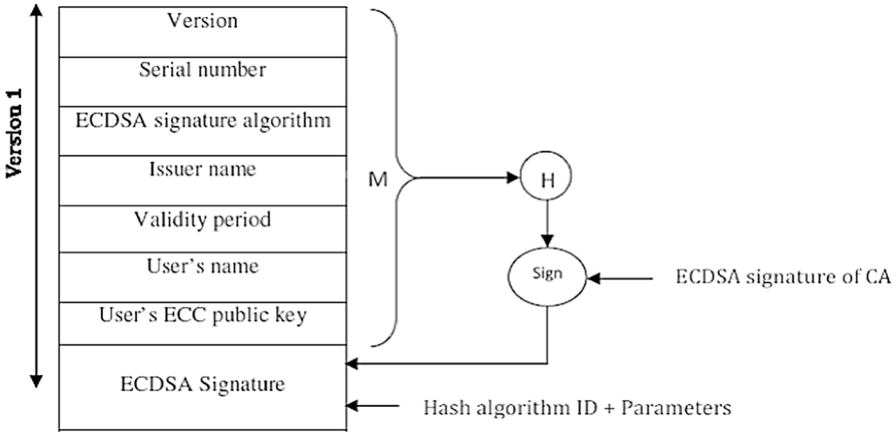



**Fig. 1** ECC-based X.509 certificate format [43]

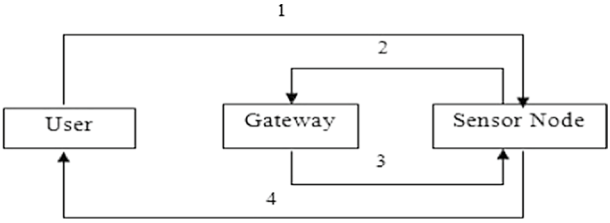



**Fig. 2** Efficient user authentication model for WSNs proposed by Xu et al. [17]

## 3 Proposed protocol

In this section, an ECC-based lightweight three-factor mutual authentication scheme for remote user in context of IoT is proposed. The proposed scheme is designed over the convenient and efficient network model for IoT network—the well-accepted fifth model proposed by Xue et al. [17] as given in Fig. 2. In this model, IoT network requires four sequential messages to communicate among each participant (remote user, sensor node, gateway) of the network. The remote user can directly contact the sensor node for mutual authentication and accordingly the node communicates the gateway for authentication. After successful authentication, the node directly transfers data to the user without any interference of the gateway. Hence, the transmission and communication cost is decreased and thus this model is supposed to be the best model for IoT communication [17, 25, 31]. On the other hand, although various mutual authentication schemes are available for IoT network, most of them have some security flaws as discussed in 'literature review' of Sect. 1. The proposed scheme not only overcomes those security flaws but meets almost all the crucial issues of IoT network like low computation and communication overheads, safety of user's credentials etc.

The proposed scheme has five phases namely—(1) Registration phase, (2) Login phase, (3) Mutual authentication and session key negotiation phase and (4) Password change phase, (5) Symmetric key update phase where the following notations are used as given in Table 1

### 3.1 Registration phase

In this subsection, the registration procedure of a user and an IoT node with the gateway of IoT network is discussed. The registration phase includes the—(a) Registration of user to gateway and (b) Registration of IoT node to gateway, which are described in this subsection.The following pre-assumptions have been done by all the communicating parties before proceeding to the registration.

*Pre-negotiated information* An elliptic curve $E/F_q$ of equation $y^2 = x^3 + ax + b$ over a prime finite field $F_q$ where $a, b, x, y \in F_q$ and satisfies the condition $4a^3 + 27b^2 \bmod q \neq 0$ with the generator of the cyclic group $G_q$ is point $P$.

**Table 1** Notation used with description

| Notation | Description |
|---|---|
| $U$ | User |
| $N$ | IoT node |
| $GW$ | Gateway |
| $E$ | Encryption |
| $D$ | Decryption |
| $h(_)$ | A one-way secure hash function |
| $\Delta T$ | Timestamp for message receiving |
| $\|\|$ | Concatenation |
| $F_q$ | A finite field |
| $E_q(a,b)$ | An elliptic curve defined over on $F_q$ with prime order $n$ |
| $P$ | A generator point on $E/F_q$ with order $n$ |
| $(\alpha, V_U)$ | Key pair (private/public) based on ECC of user $U$ where $V_U = \alpha.P$ |
| $(\beta, V_G)$ | Key pair (private/public) based on ECC of gateway $GW$ where $V_G = \beta.P$ |
| $CA_U$ | Public key certificate based on ECC of user $U$ |
| $CA_G$ | Public key certificate based on ECC of gateway $GW$ |
| $ID_U$ | Identity of user $U$ |
| $ID_N$ | Identity of IoT node $N$ |
| $B_U$ | Biometric of user $U$ |
| $Pw_U$ | Password of user $U$ |
| $x$ | Pre-secret key between IoT node $N$ and gateway $GW$ |
| $S_K$ | Shared session key negotiated between the user and IoT node |
| $K_X$ | $x$- coordinate of point $K$ |
| $L_X$ | $x$- coordinate of point $L$ |
| $R_U$ | Random point of the user |
| $R_N$ | Random point of the IoT node |
| $R_{GU}, R_{GN}$ | Random point of the gateway |

### 3.1.1 Registration of user to gateway

The user who desires to access IoT services through the application running on his smart devices required to register himself to the gateway of the IoT network. The following pre-assumptions have been done by the two parties before proceeding to the registration of the user to gateway as shown in Fig. 3.

*Pre-requisite information* User selects a private key $\alpha$ where $(1 < \alpha < n \,\&\, \alpha \in \mathbb{Z}_q^*)$ and computes its public key $V_U$ as $V_U = \alpha.P$ and accordingly acquires his public key certificate based on ECC, $CA_U$ from the certificate authority $CA$. The format and structure of the certificate is shown in Fig. 1. Similarly, the gateway of the IoT network has private/public key pair $(\beta, V_G)$ based on ECC and public key certificate $CA_G$ where, the private key $\beta$ is randomly selected such that $(1 < \beta < n \,\&\, \beta \in \mathbb{Z}_q^*)$ and the public key $V_G = \beta.P$. Since, the public keys/public key certificates remain

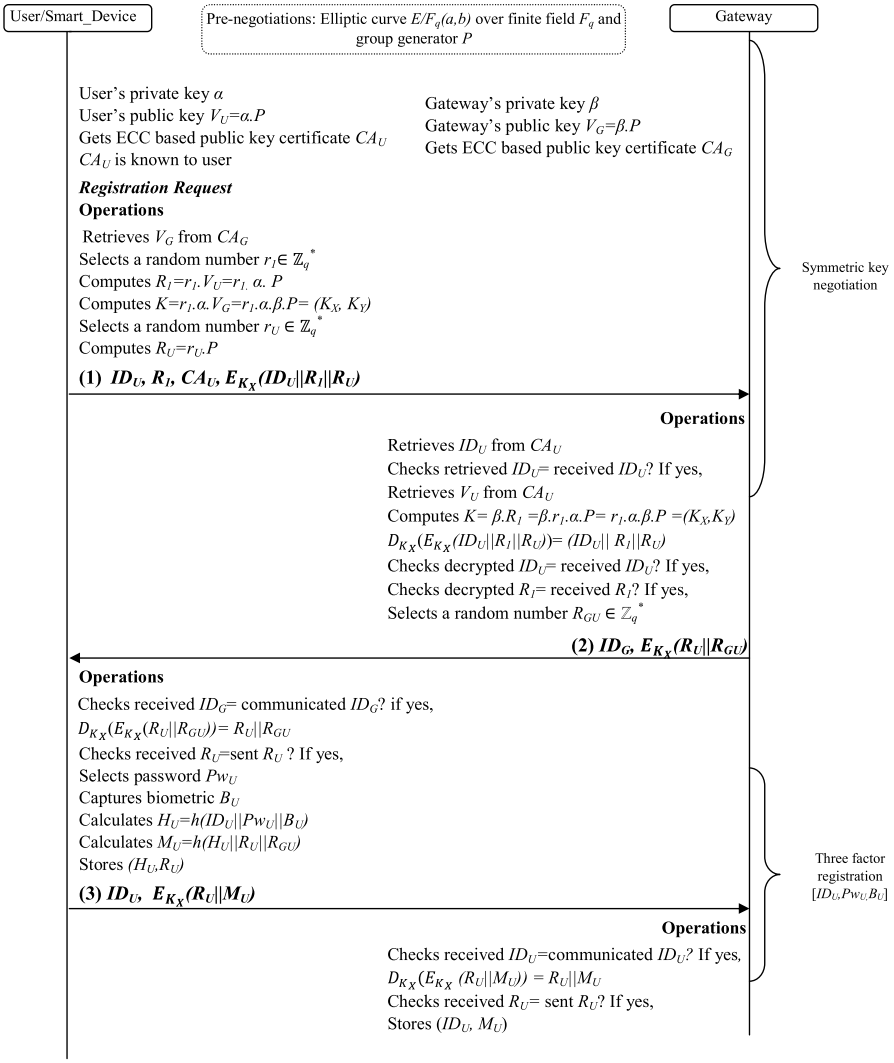



**Fig. 3** Registration of user to gateway

public and the identity of the gateway is well known to all, it is assumed that the public key of the public key of the gateway is known to the user. Now, the step-wise registration procedure between the user/smart device and the gateway is shown in Fig. 3 and described below, where $X \rightarrow Y : M$ indicates the sender $X$ sends message $M$ to the receiver $Y$.

*Step 1* user → Gateway: $ID_U, R_1, CA_U, E_{K_X}(ID_U \parallel R_1 \parallel R_U)$

User selects a random number $r_1$ such that $r_1 \in \mathbb{Z}_q^*$ and computes $R_1=r_1.P$. User retrieves the public key $V_G$ of the gateway from $CA_G$ and calculates ECDH-based contributory value $K$ as $K = r_1.\alpha.V_G = r_1.\alpha.\beta.P = (K_X, K_Y)$, where $K_X$ will be

used as a symmetric session key. Each time the user needs to update the symmetric session key the user must select a different random number to calculate ECDH-based symmetric key. Now, the user selects a random number $r_U \in \mathbb{Z}_q^*$ and computes $R_U = r_U.P$, concatenates it with his identity $ID_U$, encrypts the concatenated message using $K_X$ and finally sends his registration request composed of his—(1) identity $ID_U$, (2) ECC-based public key certificate $CA_U$, (3) Random point $R_1$ and (4) encrypted message $E_{K_X}(ID_U \parallel R_1 \parallel R_U)$ to the gateway.

*Step 2* Gateway → User: $ID_G, E_{K_X}\left(R_U \parallel R_{GU}\right)$

The gateway receives the registration request from the user, retrieves the identity of the user from $CA_U$ and checks *received* $ID_U$=*retrieved* $ID_U$? If it fails, the registration request is terminated; otherwise, the gateway retrieves the user's public key $V_U$ from $CA_U$ and calculates the same ECDH-based symmetric key $K$ as $K=\beta.R_1=\beta.r_1.\alpha.P=r_1.\alpha.\beta.P=(K_X, K_Y)$ where $K_X$ will be used for symmetric decryption/encryption. Now, the gateway decrypts the encrypted message using $K_X$, gets $ID_U R_1$ and $R_U$ and checks the integrity of the message as *decrypted* $ID_U$=*received* $ID_U$ *decrypted* $R_1$=*received* $R_1$? If both the comparisons be successful, the gateway proceeds further otherwise terminates the request immediately; the gateway selects a random number $r_{GU} \in \mathbb{Z}_q^*$ and computes $R_{GU}=r_{GU}.P$, concatenates it with the received $R_U$, encrypts the concatenated message using $K_X$ and finally sends his response to the user containing—(1) its identity $ID_G$ and (2) the encrypted message $E_{K_X}\left(R_U \parallel R_{GU}\right)$.

*Step 3* User → Gateway: $ID_U, E_{K_X}\left(R_U \parallel M_U\right)$

After receiving the response from the gateway the user ensures if *received* $ID_G$=*communicated* $ID_G$? If the verification fails, communication is aborted; otherwise, the user decrypts the encrypted message using his own $K_X$, gets $R_U$ and $R_{GU}$ and checks *received* $R_U$=*sent* $R_U$? If yes, the legitimacy of the gateway is ensured. Now, the user selects a random password $PW_U$, enters the password to his smart device, and accordingly the device captures the user's biometric $B_U$ (finger print/retina scan) and generates the hash digest $H_U$ of the three factors (identity $ID_U$, password $PW_U$ and biometric $B_U$) as $H_U = h\left(ID_U \parallel Pw_U \parallel B_U\right)$. Further, the device generates another hash digest $H_U = h\left(H_U \parallel R_U \parallel R_{GU}\right)$, concatenates it with $R_U$ and encrypts the concatenated message using $K_X$. The $H_U$ and $R_U$ are stored into the memory of the smart device and a response message containing—(1) user's identity $ID_U$ and (2) the encrypted message $E_{K_X}\left(R_U \parallel M_U\right)$ is sent to the gateway.

After receiving, the gateway checks *received* $ID_U$ = *communicated* $ID_U$? If it fails, the registration process is terminated, otherwise the encrypted message is decrypted using $K_X$, gets $R_U$, $M_U$ and received $R_U$=sent $R_U$ is checked? If yes, then the registration process of the user is completed and accordingly the gateway stores $(ID_U, M_U)$ for future communications.

### 3.1.2 Registration of IoT node to Gateway

As the IoT network propagates dynamically with the inclusion of new nodes, it is essential to integrate only legitimate nodes to the IoT network. That is why it always requires performing a registration procedure between the IoT nodes and the gateway that offers any IoT node to dynamically connect to the IoT network. The

following pre-assumptions have been done by the two parties before proceeding to the registration".

*Pre-requisite information* As mentioned earlier, the gateway has its ECC-based private–public key pair ($\beta$, $V_G$) where, private key $\beta$ is such that ($1 < \beta < n \& \beta \in \mathbb{Z}_q^*$) and the public key $V_G = \beta.P$ and accordingly has the ECC-based public key certificate $CA_G$. The IoT node has a pre-secret $x$ negotiated with the gateway during the deployment phase.

Now, the step-wise registration procedure between the IoT node and the gateway is shown in Fig. 4 and described below, where $X \rightarrow Y$: $M$ indicates the sender $X$ sends message $M$ to the receiver $Y$.

*Step 1* IoT Node → Gateway: $ID_N, R_X, E_{L_X}(ID_N \parallel R_N)$

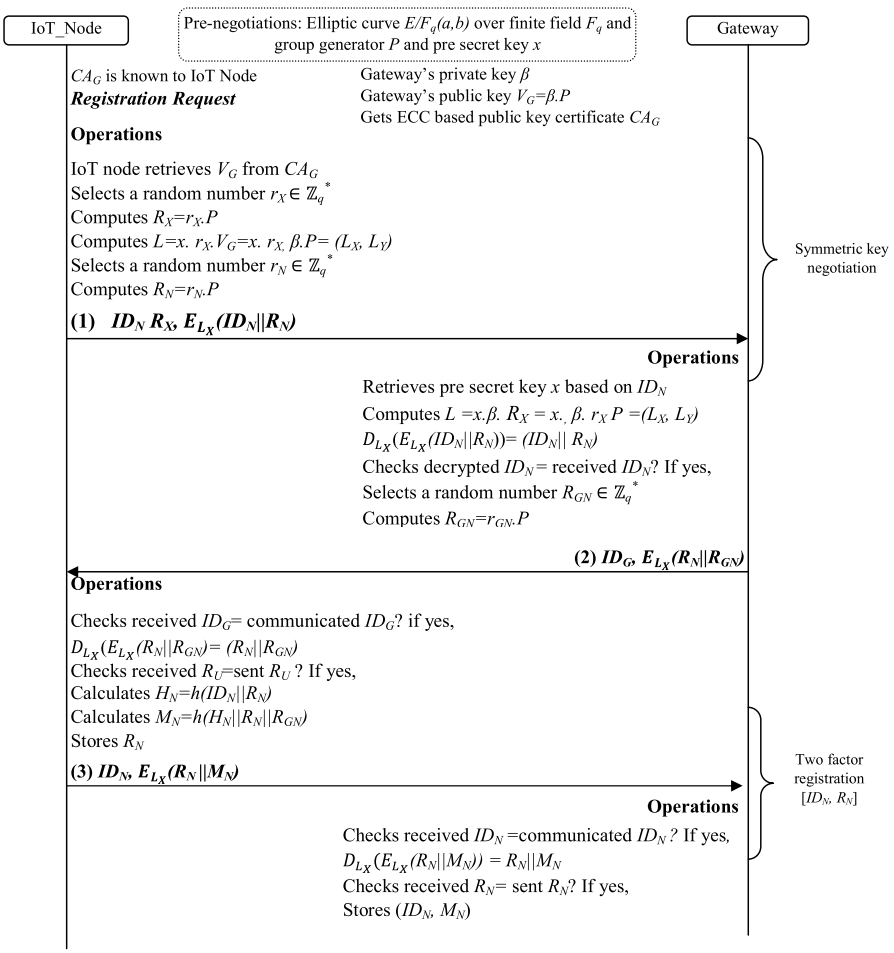



**Fig. 4** Registration of IoT node to gateway

Initially, the IoT node gets the public key of the gateway $V_G$ from $CA_G$, selects a random number $r_X$ to calculate $R_X$ as $R_X = r_X.P$ and calculates its ECDH-based contributory value $L = x.r_X.V_G = x.r_X.\beta.P = (L_X, L_Y)$ where, $L_x$ is used as the symmetric session key for encryption and decryption. The pre-secret key $x$ is used as the private key of the IoT node. Then, it selects a random number $r_N \in \mathbb{Z}_q^*$, calculates $R_N = r_N.P$, concatenates it with its identity $ID_N$, encrypts the concatenated message using $L_x$ and finally sends the registration request that contains-(1) its identity $ID_N$ (2) ECC-based point $R_X$ and (3) the encrypted message $E_{L_x}(ID_N||R_N)$ to the gateway through open channel.

*Step 2* Gateway → IoT Node: $ID_G$, $E_{L_x}\left(R_N \parallel R_{GN}\right)$

After receiving the request, the gateway retrieves the pre-secret key $x$ from its database based on the received $ID_N$ and calculates ECDH-based contributory symmetric value $L = x.\beta.R_X = x.r_X.\beta.P = (L_X, L_Y)$ where $L_X$ is used as symmetric session key for encryption/decryption.

Now, the gateway decrypts the encrypted message, gets $ID_N$ and $R_N$, checks *decrypted* $ID_N$ = *received* $ID_N$? If the verification fails, the communication is terminated; otherwise, a random number is selected $r_{GN} \in \mathbb{Z}_q^*$ and $R_{GN} = r_{GN}.P$ is computed by the gateway. Then, it concatenates $R_{GN}$ with received $R_N$, encrypts the concatenated message using $L_x$ and finally sends a response that contains—(1) its identity $ID_G$ and (2) the encrypted message $E_{L_x}\left(R_N \parallel R_{GN}\right)$ to the IoT node.

*Step 3* IoT Node → Gateway: $ID_N$, $E_{L_x}\left(R_N \parallel M_N\right)$

The node receives the response from the gateway and checks *received* $ID_G$ = *communicated* $ID_G$? If, it fails, the communication is terminated; otherwise, it decrypts the message, acquires two random points $R_N$ and $R_{GN}$ and checks *received* $R_N$ = *sent* $R_N$? If yes, it is ensured that the message is coming from the legitimate gateway. Now, the node calculates two hash digests $H_N = h\left(ID_N \parallel R_N\right)$ and $M_N = h\left(H_N \parallel R_N \parallel R_{GN}\right)$, concatenates $M_N$ and $R_N$, encrypts the concatenated message using $L_x$ and finally sends a reply that contains—(1) its identity $ID_N$ and (2) encrypted message $E_{L_x}\left(R_N \parallel M_N\right)$ to the gateway.

After receiving the reply, the gateway checks received $ID_N$ = stored $ID_N$? If it fails, the registration process is terminated; otherwise it decrypts the message using $L_X$, gets $R_N$ accordingly the gateway stores $(ID_N, M_N)$ for future communications.

### 3.2 Log-in phase

In this subsection, the log-in procedure between the user and his smart device is discussed. After successful completion of registration phase user can communicate to any preferred IoT node of the IoT network through his smart device. To do this user first needs to successfully log-into the application running on his smart device. The proposed log-in scheme has the provision for verifying the user's authenticity by the smart device based on user's personal credentials like biometric, password etc. The proposed log-in phase is given in Fig. 5 and elucidated below.

User → Smart device: $ID_U$, $Pw_U$, $B_U$

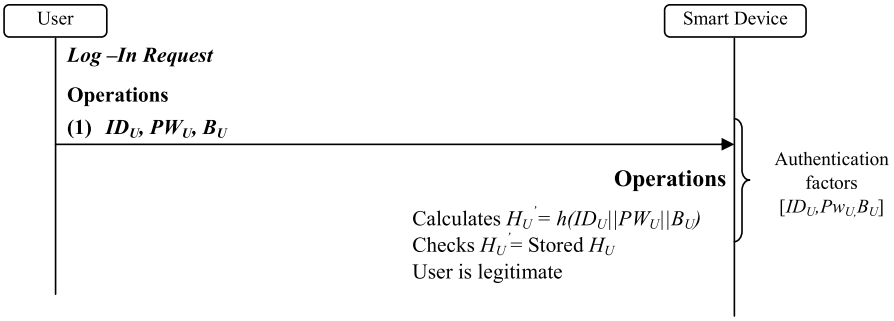



**Fig. 5** Log-in phase

The user enters his secret information—(1) identity $ID_U$ and (2) password $Pw_U$ to the smart device for log-in and the device automatically captures the user's biometric $B_U$. After receiving these user's credentials, the smart device calculates hash digest $H'_U$ as $H'_U = h\big(received\ ID_U \parallel received\ PW_U \parallel received\ B_U\big)$.

Then it checks *calculated* $H_U' =$ *stored* $H_U$? If it is true then the user is the legitimate user and login is successful. To be well protected from different security attacks this scheme limits the number of log-in requests using a variable '$count \leq 5$' which is initialized to zero. Each time a user requests for login the 'count' is increased by one. If the legitimacy of the user fails for five times, the device blocked the user for a specific period of time.

### 3.3 Mutual authentication and session key negotiation phase

Initially the user/smart device and IoT nodes have registered to the gateway of the IoT network. In order to acquire IoT services the user's smart device sends an authentication request directly to the desired IoT node. The goal of this phase is to mutually authenticate and negotiate a secret session key between the user/device and IoT node through gateway for seamless communication without any intervention of the gateway. The diagrammatic representation of this phase is shown in Fig. 6 and described below where $X \rightarrow Y$: $M$ indicates the sender $X$ sends message $M$ to the receiver $Y$.

*Step 1* User → IoT Node: $ID_U, E_{K_X}\big(H_U \parallel R_U\big), T_1$

After successful log-in of the user, the smart device concatenates the $H_U$ and stored $R_U$, encrypts the concatenated message using $K_x$, records the current time $T_1$ and finally sends the authentication request composed of—(1) user's identity $ID_U$ (2) the encrypted message $E_{K_X}\big(H_U \parallel R_U\big)$ and (3) the recorded time $T_1$ to the IoT node. Here, we have assumed that clock is synchronized with the global time.

*Step 2* IoT Node → Gateway: $ID_N, E_{L_X}\big(H_N \parallel R_N\big)\}, \{ID_U, E_{K_X}\big(H_U \parallel R_U\big)\}T_2$

The IoT node receives the authentication request and forwards the same to the gateway along with its own credentials for verification. For sending its credentials,

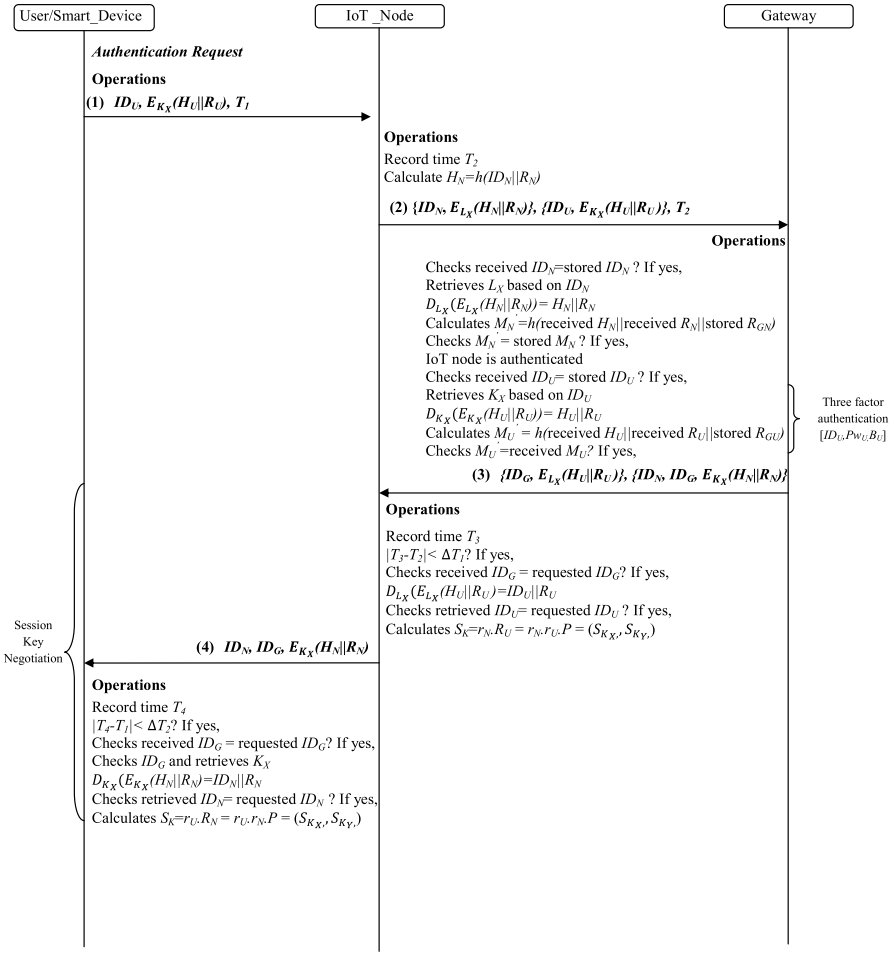



**Fig. 6** Authentication and session key agreement phase

it calculates $H_N$ as $H_N = h(ID_N \parallel R_N)$, concatenates the calculated $H_N$ with stored $R_N$, encrypts the concatenated message using $L_x$, the symmetric session key negotiated with the gateway during registration. The encrypted message, the identity of the node $ID_N$ and the recorded time $T_2$ is sent to the gateway as its credential for authentication.

*Step 3* Gateway → IoT Node : $\{ID_G, \boldsymbol{E_{L_X}}(H_U \parallel R_U)\}, \{ID_N, ID_G, E_{K_X}(H_N \parallel R_N)\}$

After receiving the first message sent by the IoT node the gateway checks *received* $ID_N$ = *stored* $ID_N$? If it is true, it retrieves the prior negotiated symmetric session key $L_x$ based on $ID_N$, decrypts the message using $L_X$, receives $H_N$ and $R_N$, calculates $M_N'$ as $M_N'$ = $h$(*received* $H_N$||*received* $R_N$||*stored* $R_{GN}$), checks the *calculated* $M_N'$ = *stored* $M_{N?}$ If it is true, then the three factors (identity, pre-secret

key and the random point) of IoT node are verified. Hence, the IoT node is legitimate otherwise the process is aborted.

After being confirmed about the legitimacy of the IoT node, the gateway accepts the user's authentication message forwarded by the IoT node and compares *received* $ID_U$ = *stored* $ID_U$? If yes, it retrieves the symmetric session key negotiated during registration, $K_x$ for that specific user, decrypts the received message using $K_X$, gets $H_U$ and $R_U$, calculates $M'_U$ as $M'_U = h(\textit{received } H_U \parallel \textit{received } R_U \parallel \textit{stored } R_{GU})$ and finally checks *calculated* $M'_U$ = *stored* $M_U$? If it fails, the communication is terminated; otherwise all the authentication factors of the registered user are verified. Hence, the remote user $U$ is authenticated.

Now, the gateway sends two reply messages to the IoT node—the first part is for the IoT node and the last part is for the specified user, respectively. The first message is composed of (1) identity of the gateway $ID_G$ (2) concatenated form of user identity $ID_U$ and $R_U$ of the requested user $U$ encrypted using $L_X$. The last message contains–(1) identity of the IoT node $ID_N$ (2) identity of the gateway $ID_G$ and (3) the concatenated form of $ID_N$ and $R_N$ of the IoT node encrypted using $K_X$.

*Step 4* IoT node → User*:* $ID_N, ID_G, E_{K_X}(H_N \parallel R_N)$

After receiving the reply from the gateway the IoT node records the current time $T_3$ and checks if $T_3$-$T_2$<$\Delta T_1$? If yes, verifies *received* $ID_G$ = *requested* $ID_G$? If it is true, then it decrypts the message, gets $ID_U$ and $R_U$ and compares the *decrypted* $ID_U$ = *requested* $ID_U$. If any mismatch is found the communication is aborted; otherwise the IoT node accepts the $R_U$ and calculates the ECDH-based symmetric session key $S_K$ for the communication with the user $U$ as $S_K = r_N.R_U = r_N.r_U.P = (S_{K_X}, S_{K_Y})$. The IoT node also forwards the last part of the received message to the requested user/device.

User's smart device receives the response from the requested IoT node, records the receiving time $T_4$ and checks the timestamp $T_4 - T_3 < \Delta T_2$? If yes, the user verifies the *received* $ID_N$ = *requested* $ID_N$ and received $ID_G$ = communicated $ID_G$? If yes, decrypts the encrypted message using $K_x$, acquires $ID_N$ and $R_N$, and compares the *decrypted* $ID_N$ = *requested* $ID_N$. If any disparity is found the communication is aborted; otherwise the device accepts the $R_N$ and calculates the same ECDH-based symmetric session key $S_K$ as $S_K = r_U.R_N = r_U.r_N.P = (S_{K_X}, S_{K_Y})$.This negotiated session key is used for symmetric encryption for further message communication between the IoT node and the remote user/device.

### 3.4 Password change phase

To increase the security strength as well as to be protected from the unauthorized access, user must update his password in a regular time interval. This scheme holds the provision of efficient password changing by the user. The diagrammatic representation of the user's password change is shown in Fig. 7 and described below where X → Y:$M$ indicates the sender $X$ sends message $M$ to the receiver $Y$.

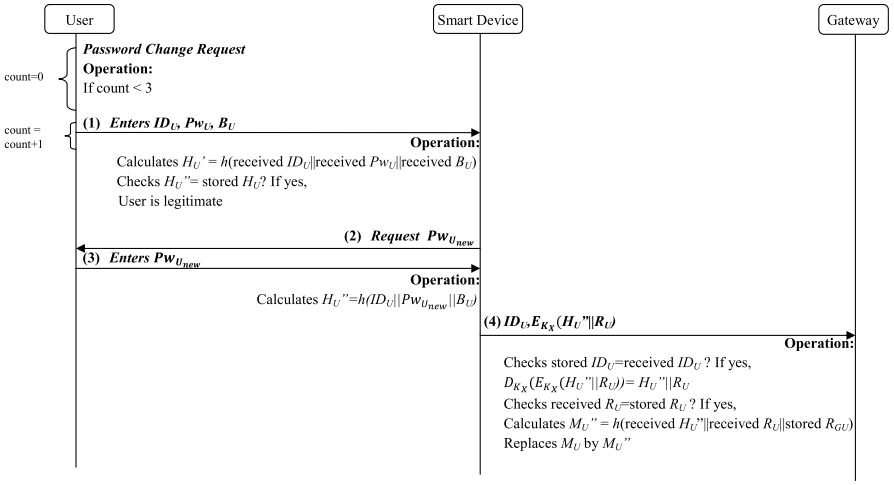



**Fig. 7** Password change phase of user

*Step 1* User → Smart device: $ID_U$, $Pw_U$, $B_U$

User selects password change option available at his smart device and enters his identity $ID_U$, old password $Pw_U$ and biometric $B_U$.

*Step 2* Smart Device → User*: Request for* $Pw_{U_{new}}$

The device calculates $H_U^{'}$as $H_U^{'} = h$(received $ID_U$|received $Pw_U$|received $B_U$) and checks the *calculated* $H_U^{'} =$ *stored* $H_U$? If yes, the user is legitimate and accordingly user is requested to enter his new password $Pw_{U_{new}}$; otherwise the user has to re-enter his credentials to the device. The user is allowed to enter his credentials maximum three times.

*Step 3* User → Smart device:$Pw_{U_{new}}$

User inputs his new password $Pw_{U_{new}}$ to the device.

*Step 4* Smart device → Gateway: $ID_U$,$\boldsymbol{E_{K_X}}(H_U^{''}||R_U)$

After receiving the new password $Pw_{Unew}$ the device computes new hash digest of the user's credentials $H_U'' = h(ID_U \parallel Pw_{U_{new}} \parallel B_U)$, concatenates $R_U$ and $H_U^{''}$, encrypts the concatenated message using $K_x$ and finally sends the identity of the user $ID_U$ and the encrypted message to the gateway so that the gateway is aware of the change.

After receiving the message the gateway initially checks *received* $ID_U =$ *stored* $ID_U$? If it fails, the communication is terminated; otherwise the gateway decrypts the message using $K_X$, the symmetric session key negotiated during registration, gets $R_U$ and $H_U^{''}$and verifies *received* $R_U =$ *stored* $R_U$? If it is true, the gateway calculates $M_U'' = h\big($*received* $H_U \parallel$ *received* $R_U \parallel$ *stored* $R_{GU}\big)$ and replaces the stored $M_U$ with the calculated $M_U^{''}$.

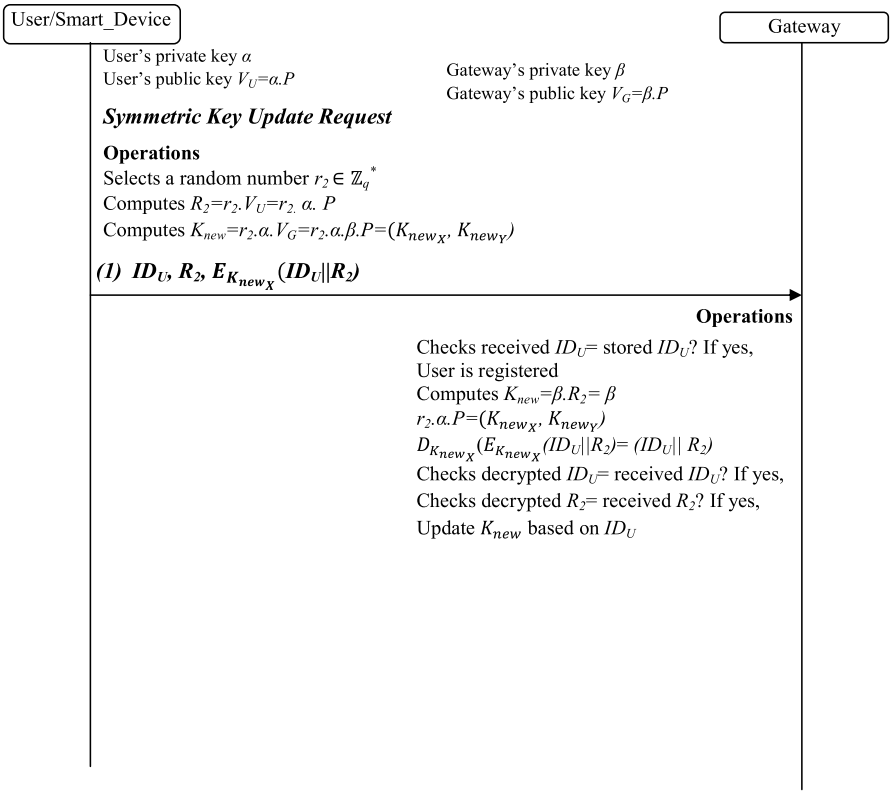



**Fig. 8** Symmetric key update phase of user

### 3.5 Symmetric key update phase

ECDH-based symmetric key, computed during registration phase of the user, is frequently required for communication between user and gateway. This pre-computed ECDH-based key needs to update in a regular time interval, so that it can be protected from different security attacks. The symmetric key composed of a random number which makes the key dynamic and variable. This scheme provides the provision of efficient symmetric key update by the user. The diagrammatic representation of the user's key update is shown in Fig. 8 and explained below where $X \rightarrow Y$: $M$ means the sender $X$ sends message $M$ to the receiver $Y$.

*Step 1* User → Gateway: $ID_U$, $R_2$, $E_{K_{new_X}}(ID_U \parallel R_2)$

If any registered user wants to update symmetric session key he selects a different random number $r_2$ such that $r_2 \in \mathbb{Z}_q^*$ and computes $R_2 = r_2.V_U$ where $V_U$, public key of the user, $V_U = r_2.\alpha.P$. Then the user computes ECDH-based new symmetric key $K_{new}$ as $K_{new} = r_2.\alpha.V_G = (K_{new_X}, K_{new_Y})$ where $V_G$ is the public key of the gateway. Next, the user sends symmetric key update request to gateway containing composed of: (1) the

identity of the user $ID_U$, (2) Random point $R_2$ and (3) the concatenated form of $ID_U$ and $R_2$ of the IoT node encrypted using, $E_{K_{new_X}}$.

After receiving the request the gateway first checks if the user is already registered or not. If $ID_U$ is stored then the user is registered. Then it computes new ECDH-based new symmetric key $K_{new}$ as $K_{new} = \beta.R_2 = (K_{new_X}, K_{new_Y})$ where $\beta$ is the private key of the gateway. Then it decrypts the later part of the message to get $ID_U$ and $R_2$. Now, the gateway checks the decrypted $ID_U$ is similar to the received $ID_U$ and also checks if the decrypted $R_2$ is same as received $R_2$? If both the conditions are true then the gateway update ECDH-based symmetric key as $K_{new}$.

## 4 Security analysis

The security of any remote user authentication protocol in IoT network is most important although it is very hard to achieve. In this section, we have considered various existing security threats applicable to the proposed scheme and analyzed the fortification against those attacks in details to ensure that the proposed scheme is well-protected.

### 4.1 Man-in-the-middle attack

This attack takes place when an attacker comes in between the sender and receiver and represents himself as one of the sender/receiver. Thus, the attacker not only silently listens to the communication channel between the sender and receiver but also retrieves, alters or deletes the messages with a delay. In the proposed scheme initially any new user and IoT node needs to register and authenticate with gateway in IoT network. During registration of the remote user the ECC-based public key certificate is used for initial communication, i.e., the identity and public key pair of the valid user is authentic and no adversary can change it. In addition, an ECDH-based contributory symmetric session key is negotiated between the user and the gateway as well as the IoT node and the gateway for all the future communications.

As affirmed in Sect. 3.3, a three-factor-based user authentication (the user's identity, password and biometric) is used to verify the legitimacy of the user by the user's device. Similarly, to validate the legitimacy of the IoT node the three factors of the node (identity, pre-secret key and random point) are verified by the gateway during authentication phase. The gateway also validates the parameters ($M_U$,$R_U$, $M_N$, $R_N$) of the user and the IoT node using one-way hash function. Moreover, the prior negotiated symmetric session key is used to encrypt and send the contributory part of the session key to be negotiated at the end of the authentication and session key negotiation phase. Hence, forging the contributory part of the session key by any attacker in the middle is impossible. Further, consider the following actions as used in Fig. 6.

| | |
|---|---|
| Message for user authentication | $ID_U, E_{K_X}(H_U \parallel R_U)$which includes $H_U$ that is calculated as $H_U = (ID_U \parallel PW_U \parallel B_U)$ |
| Alteration done by adversary | $\bar{H}_U = h(ID_U \parallel PW_U \parallel B_U)$. It is assumed that identity and password are stolen of any valid user, but biometric of the attacker is captured automatically by the device. Thus *calculated* $\bar{H}_U \neq$ *stored* $H_U$ |

Hence, the man-in-the-middle attack is detected.

### 4.2 Replay attack

Replay attack means a previously transmitted valid message is maliciously repeated or retransmitted to the receiver to proof that the message is coming from the allowed entity. In the proposed scheme if an attacker tries to authenticate himself as legitimate user by replaying the message sent by the user and gateway without altering the original one that is easily detected. This is because a pre-determined timestamp value $\Delta T$, the only permissible time to accept any reply/response, is used during message transfer for protecting this attack.

Let us assume that to start a new session with the IoT node the user authentication request $ID_U$, $E_{K_X}(H_U \parallel R_U)$, $T_1$ of the previous session as mentioned in Fig. 7 is intercepted by the attacker and retransmitted to the IoT node that contains $ID_U$, $E_{K_X}(H_U \parallel R_U)$, $T_5$. Accordingly after receiving the reply message $ID_N$, $ID_G$, $E_{K_X}(H_N \parallel R_N)$ the user records the current time $T_4$ which concludes $|T_4 - T_3| \neq \Delta T_2$. Hence, the proposed scheme is well protected against the replay attack.

### 4.3 Gateway impersonation attack

An attacker may impersonate the gateway by falsely proving himself as a legal entity and tries to send the message by eavesdropping a transmitted valid message over the communication channel in such a way that the message is coming from the original gateway.

In the proposed registration phase, the remote user/device and the IoT node retrieve the identity and the public key $V_G$ of the gateway from its ECC-based public key certificate and use the same public key to calculate the contributory shared session key using ECDH. The contributory part of the key of each party is never communicated over any channel. Hence, calculating the shared contributory key between the user and the gateway is done as $K = \beta.R_1 = \beta.r_1.\alpha.P = r_1.\alpha.\beta.P = (K_X,K_Y)$ and between the IoT node and the gateway as $L = x.\ V_G = x.\beta.P = (L_X, L_Y)$. Thus the shared key contains the private key of the sender (user/IoT node) and the public key of the receiver (gateway) retrieved from the ECC-based certificate. Hence, impersonation of the gateway by any adversary is not possible during proposed registration phase.

Further, in the proposed authentication and session key negotiation phase the following operations may happen as used in Fig. 6.

| | |
|---|---|
| Reply to authentication request of the user | The gateway sends $ID_N$, $ID_G$, $E_{K_x}(H_N \parallel R_N)$; now, let us assume that the attacker is able to impersonate the gateway by compromising $K_X$ and alters the random point $R_N$ as $R_N^{'}$ and sends it to the IoT node. |
| Session key negotiation | Session key is generated as $S_K = r_N.R_U = r_N.r_U.P = (S_{K_x}, S_{K_y},)$ where $r_u$ and $r_n$ are two random numbers known only to the user and the IoT node, respectively. |

Hence, the proposed scheme is well protected against this attack.

### 4.4 User impersonation attack

If an attacker tries to impersonate himself as a legal user to the gateway using some of the private information of the user then this attack is successfully executed.

In our scheme, the ECC-based public key certificate of the valid user is sent with the initial registration request containing $ID_U$, $R_1$, $CA_U$, $E_{K_X}(ID_U \parallel R_1 \parallel R_U)$. Thus, the identity and the public key pair of the user are authentic and the identity of the user cannot be forged.

Let us assume that an attacker successfully traps a valid log-in request and tries to generate valid authentication request using the log-in request. For doing that he needs to know $R_U$ and compute $K_X$. However, the attacker cannot compute $K_X$ within a polynomial time due to the hardness of ECDLP. Moreover it is impossible to guess $R_U$ without the knowledge of $r_U$ which is a secret random number known to the user only. Thus, the attacker cannot be able to impersonate himself as a legitimate user.

### 4.5 Denial-of-services (DoS) attack

In this attack the attacker seeks to make a network resource unavailable to the genuine user by disrupting the services of the server by sending several bogus requests to the gateway. To protect this attack the proposed scheme limits the number of user's login/authentication attempts to the device/gateway to maximum three. If the user/device fails to provide his credentials within three attempts, the login as well as authentication will be aborted for the specific user/device for a elongated period. Thus the DoS attack is well protected in the proposed scheme.

### 4.6 Lost/stolen device attack

If the user's smart device is lost or filched, the attacker can retrieve all the sensitive information stored in the memory device of the smart device using power analysis attack and using that retrieved secret information the attacker may obtain other related secret data.

However, in our scheme, device memory does not directly store user's identity, password or biometric information. It stores $H_U$, the hash digest of $ID_U \parallel PW_U \parallel B_U$ . To guess the users's password and biometric from $H_U$ is almost impossible as hash function is irretrievable. Furthermore, the device memory stores a random point $R_U$

generated by user. $R_U$ is calculated by point multiplication of ECC using a random no $r_U$ over a large prime finite field $F_q$. As ECDLP is an np- hard problem to solve, attacker cannot be able to guess the random number in polynomial time. Thus the proposed scheme is safe from stolen device attack.

### 4.7 Offline guessing attack

Due to the use of low entropy identity and password any attacker can easily guess the password in polynomial time using brute force attack or may intercept the password in any offline mode.

Let us assume that an attacker is intercepting the proposed login phase using the low entropy identity and password of a user. However, the attacker remains unsuccessful to authenticate himself to the device since the three-factor verification is performed by the device by calculating $\bar{H}_U = h\big(received\ ID_U \big|\big| received\ PW_U \big|\big| received\ B_U\big)$ and comparing the *calculated* $\bar{H}_U$ = *stored* $H_U$? Since the biometric $B_U$of the attacker is automatically captured by the device and guessing of user's biometric $B_U$ is not possible, the offline guessing attack cannot occur in the proposed login phase.

Further, if an attacker is intercepting a previous message $ID_U$, $E_{K_X}\big(H_U \parallel R_U\big)$ sent by the user during registration phase where $K_X$ is the contributory shared secret key, it is practically impossible to the attacker to guess the key $K_X$ and accordingly the different secret points $R_U$, $R_{GU}$ negotiated between user and gateway due to the hardness of ECDLP. Hence, the proposed scheme is safe against the offline guessing attack.

### 4.8 Spoofing attack

In the proposed scheme spoofing attack can be of two types—(1) user log-in/authentication and key negotiation spoofing and (2) gateway spoofing. In type (1) a user who wants to acquire services from IoT network needs to authenticate himself using his credentials—identity, password and biometric through three-factor authentication. In this case, consider the following:

| | |
|---|---|
| A valid log-in request: | The device calculates $H'_U = h\big(received\ ID_U \parallel received\ PW_U \parallel received\ B_U\big)$ and checks $H'_U$ = *stored* $H_U$ ? Hence, the verification of $H_U$ explicitly verifies the user's identity and biometric by the device. |
| A valid authentication request: | The device after local verification of $H_U$ sends the authentication request $ID_U$, $E_{K_x}(H_U \| R_U)$ to the gateway. |
| Gateway's verification: | After receiving the authentication request, the gateway calculates $M'_U = \big(received\ H_U \parallel received\ R_U \parallel stored\ R_{GU}\big)$ and checks calculated $M_U$ = stored $M_U$? Thus the verification of $M_U$ implicitly verifies the user's credentials as well as the secret points negotiated during registrations. |

Hence, the type (1) spoofing attack is not possible in the proposed scheme.

For type (2) spoofing attack, let us assume that an attacker tries to spoof the gateway's response to the authentication request to the IoT node. In this case, consider the following:

| | |
|---|---|
| Gateway's response to authentication request | Gateway sends $\{ID_G, E_{L_X}(H_U \parallel R_U)\}$, $\{ID_N, ID_G, E_{K_X}(H_N \parallel R_N)\}$ to the IoT node for session key establishment. Let the attacker tempers the gateway's message and gets $R_U$ and $R_N$ |
| Session key negotiation | To calculate the session key $S_K = r_N.R_U = r_N.r_U.P = (S_{K_X}, S_{K_Y})$, the secret random numbers $r_U$ and $r_N$ (known to the user and IoT node only) are required. Since, $r_U$ and $r_N$ are unknown to the attacker; hence, the session key can never be established using the retrieved $R_U$ and $R_N$ only due to the hardness of ECC point multiplication. |

Hence, the type (2) spoofing attack is not possible in the proposed scheme.

### 4.9 Forward secrecy

This perfect forward secrecy means the disclosure of user's prior negotiated key cannot be able to compromise the secure session key to be negotiated later during the succeeding session.

In our scheme, initially a symmetric key $K_X$ is negotiated between the user and the gateway during the registration phase as $K = r_1.\alpha.V_G = r_1.\alpha.\beta.P = (K_X, K_Y)$ where $\alpha$ and $\beta$ are the private key of the user and the gateway, respectively. Later, the $K_X$ is used to encrypt and send the contributory key part of the session key $SK_X$ to be negotiated at the end of the authentication and session key negotiation phase as $S_K = r_U.R_N = r_U.r_N.P = (S_{K_X}, S_{K_Y})$ where $r_U$ is the secret random number known to the user only.

Let us assume that somehow $K_x$ is compromised by the attacker. So the attacker is able to decrypt the reply message $E_{K_X}(ID_N \parallel R_N)$ to the user from the IoT node as shown in *step-3* in Fig. 6. Thus, the attacker gets $R_N$ and tries to calculate the $SK$ but the attacker will not be successful since the attacker requires $r_U$ which the secret random number acknowledged to the user only. The $r_U$ is completely secret and the attacker cannot be able to compromise it by guessing due to the vast key domain of $\mathbb{Z}_q^*$ in ECC. Thus, the attacker cannot be able to calculate the session key $SK$. Hence, the proposed scheme holds the perfect forward secrecy.

### 4.10 Gateway bypassing attack

In the proposed scheme the gateway plays a trusted role to authenticate both the user and the IoT node. Hence, bypassing the gateway means bypassing the authentication process. In the proposed scheme initially the user needs to communicate with the IoT node for accessing IoT service. Subsequently the IoT node forwards the authentication request to the gateway for verification. Thus, the IoT node entrusted

the authentication process to the gateway and then the gateway verifies both the IoT node and the user. Thus, the proposed scheme is well protected against the gateway bypassing attack.

### 4.11 User anonymity

User anonymity means during the communications through open channel, leakage of user's credentials may happen and that leads to eavesdrop of the same by the adversary.

In the proposed scheme the user credentials are transmitted after encryption using the negotiated session key and the hash digest of the user credentials is also calculated as $H_U = h(ID_U \parallel PW_U \parallel B_U)$ and sent together over the channel. Thus, it is practically infeasible to extract the user credentials from the encrypted message as well as from the hash digest. Hence, the proposed scheme is free from this attack.

### 4.12 Parallel session attack

If the attacker captures the login request of a valid user containing $ID_U$ and $Pw_U$, and accordingly initiates a parallel session, the biometric of the attacker is automatically captured by the device. Hence, the attacker is unable to provide the user's original biometric which is essential for successful log-in. Thus, the proposed scheme is free from the parallel session attack.

## 5 Performance analysis

This section demonstrates the performance of the proposed scheme in terms of computation overhead, communication overhead, storage cost and security features. The system set up includes the platform, i.e., core i5 machine with Windows 7 Professional operating system, 2.50 GHz processor and 4.0 GB of internal memory. To compute the overheads, the timings for the primitive arithmetic and cryptographic operations are considered and PBC library (version 0.5.12) [49] which is based on the GMP Library (version 5.0.5) is employed. We evaluate the performance of the proposed scheme by comparing it with some related authentication schemes [8–10, 17, 24–26, 30, 31, 33, 34, 36] which are previously proposed for IoT environment.

### 5.1 Security functionality

The comparison of the proposed scheme with the some benchmark remote user authentication schemes is summarized in Table 2, sorted chronologically, in terms of various security attacks and essential security features. It is found that our scheme holds all the security functionalities. Therefore, it can be concluded that the proposed scheme is secure against relevant existing security attacks and provides security features.

**Table 2** Comparison of security features between the proposed scheme and other related schemes. [8–10, 17, 24–26, 31, 33, 34, 36]

| Feature | | | | | | | | | | | | | | |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| Schemes | $SF_1$ | $SF_2$ | $SF_3$ | $SF_4$ | $SF_5$ | $SF_6$ | $SF_7$ | $SF_8$ | $SF_9$ | $SF_{10}$ | $SF_{11}$ | $SF_{12}$ | $SF_{13}$ | $SF_{14}$ |
| Xue et al [17] | X | ✓ | X | ✓ | X | ✓ | ✓ | ✓ | ✓ | X | X | ✓ | ✓ | X |
| Poorambage et al [25] | ✓ | ✓ | X | ✓ | X | ✓ | ✓ | X | X | - | - | - | ✓ | X |
| Turkanovic et al [26] | ✓ | ✓ | X | X | ✓ | X | ✓ | ✓ | ✓ | X | X | ✓ | X | X |
| Das et al [10] | ✓ | ✓ | X | X | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | X | ✓ | ✓ | X |
| Cheng and Le [30] | ✓ | ✓ | ✓ | X | ✓ | ✓ | X | ✓ | ✓ | X | X | ✓ | ✓ | X |
| Jiang et al [8] | ✓ | ✓ | ✓ | X | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | X |
| Dhillon and Karla [31] | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| Challa et al [33] | ✓ | ✓ | X | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | X | X | ✓ | ✓ | X |
| Sharma and Karla [24] | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| Wazid et al [9] | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | X | ✓ | ✓ | ✓ |
| Shuai et al [36] | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | X | ✓ | X | ✓ | ✓ |
| Fakroon et al [34] | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | X | ✓ | X | ✓ | ✓ |
| Our scheme | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |

| Feature | | | | | | | |
|---|---|---|---|---|---|---|---|
| Schemes | $SF_{15}$ | $SF_{16}$ | $SF_{17}$ | $SF_{18}$ | $SF_{19}$ | $SF_{20}$ | $SF_{21}$ |
| Xue et al [17] | ✓ | ✓ | X | ✓ | ✓ | X | ✓ |
| Poorambage et al [25] | ✓ | ✓ | X | ✓ | ✓ | ✓ | X |
| Turkanovic et al [26] | X | ✓ | ✓ | ✓ | ✓ | – | ✓ |
| Das et al [10] | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| Cheng and Le [30] | X | ✓ | ✓ | ✓ | X | X | X |
| Jiang et al [8] | X | ✓ | ✓ | ✓ | X | X | X |
| Dhillon and Karla [31] | ✓ | ✓ | ✓ | X | ✓ | X | X |
| Challa et al [33] | ✓ | ✓ | X | ✓ | ✓ | ✓ | ✓ |

**Table 2** (continued)

| Feature | | | | | | | |
|---|---|---|---|---|---|---|---|
| Schemes | $SF_{15}$ | $SF_{16}$ | $SF_{17}$ | $SF_{18}$ | $SF_{19}$ | $SF_{20}$ | $SF_{21}$ |
| Sharma & Karla [24] | ✓ | ✓ | ✓ | ✓ | ✓ | X | X |
| Wazid et al [9] | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| Shuai et al [36] | ✓ | ✓ | ✓ | X | ✓ | ✓ | ✓ |
| Fakroon et al [34] | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| Our scheme | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |

$SF_1$ : Mutual authentication, $SF_2$: Session key agreement, $SF_3$: User anonymity, $SF_4$: Sensor anonymity, $SF_5$: User impersonation attack $SF_6$ : Sensor node impersonation attack, $SF_7$: Gateway/server impersonation attack, $SF_8$: Man in the middle attack, $SF_9$: Replay attack, $SF_{10}$: Offline password-guessing attack, $SF_{11}$: Lost/stolen device/smart card attack, $SF_{12}$: Stolen verifier attack, $SF_{13}$: Parallel session attack, $SF_{14}$: Privileged insider attack, $SF_{15}$: Session specific temporary information attack, $SF_{16}$: Gateway node bypassing attack, $SF_{17}$: Untraceability, $SF_{18}$: Perfect forward secrecy, $SF_{19}$: Freely password change facility, $SF_{20}$: Dynamic node addition, $SF_{21}$ : Timely Typo detection. ✓: Free from the attack, x: attack is possible

**Table 3** Time requirement for different cryptographic operations

| Notation | Required execution time for operation | Time(ms) |
|---|---|---|
| $T_{ECM}$ | ECC scalar multiplication | 17.1 |
| $T_H$ | One-way hash function (SHA-1) | 0.32 |
| $T_{SE/D}$ | Symmetric encryption/decryption | 5.6 |
| $T_C$ | Chebyshev chaotic map operation | 0.32 |
| $T_{fe}$ | Fuzzy extraction operation | 17.1 |

**Table 4** Comparison of computational overhead with existing schemes [8, 9, 25, 26, 30, 31, 33, 36]

| | User | IoT_node | Gateway | Total |
|---|---|---|---|---|
| Poorambage et al. [25] | $8T_H+4T_{ECM}$ = 70.96 | $10T_H+11T_{ECM}$ = 191.3 | $5T_H+8T_{ECM}$ 141.6 | 403.86 |
| Turkanovic et al. [26] | $7T_H$ = 2.24 | $7T_H$ = 2.24 | $5T_H$ = 1.6 | 6.08 |
| Cheng & Le [30] | $9T_H+2T_{ECM}$ = 37.08 | $5T_H+2T_{ECM}$ = 35.8 | $7T_H$ = 2.24 | 75.12 |
| Jiang et al. [8] | $7T_H$ = 2.24 | $5T_H$ = 1.6 | $10T_H$ = 3.2 | 7.04 |
| Dhillon and Karla [31] | $8T_H$ = 2.56 | $6T_H$ = 1.92 | $8T_H$ = 2.56 | 7.04 |
| Challa et al. [33] | $1T_{fe}+5T_H+5T_{ECM}$ = 104.2 | $3T_H+4T_{ECM}$ = 70 | $4T_H+5\ T_{ECM}$ = 86.78 | 260.98 |
| Wazid et al. [9] | $1T_{fe}+13T_H+2T_{SE/D}$ = 32.46 | $4T_H+2\ T_{SE/D}$ = 12.48 | $5T_H+4T_{SE/D}$ = 24 | 68.94 |
| Shuai et al. [36] | $6T_H+1T_{ECM}$ = 19.02 | $7T_H+1T_{ECM}$ = 19.34 | $3T_H+1T_{ECM}$ = 18.06 | 56.42 |
| Our scheme | $2T_H+1T_{ECM}+2T_{SE/D}$ = 28.94 | $1T_H+1T_{SM}+2T_{SE/D}$ = 28.62 | $2T_H+4T_{SE/D}$ = 23.04 | 80.6 |

## 5.2 Computation overhead

The computation overhead is evaluated by identifying the primitive operations used in the schemes. Table 3 shows the important notations of the primitive operations and time required for the operations [50, 51]. The overhead is separately calculated for all the participants like user, IoT_node and gateway.

Table 4 demonstrates all the overheads of the individual participants, i.e., user, gateway, IoT_node for the log-in and mutual authentication phase. From the comparison Table 4 it can easily be identified that the proposed scheme bears more computation overhead in compared to some protocols [8, 31, 36]. This supplementary overhead can be reasonable because the proposed scheme provides more functionality and better security. Thus it maintains required security–performance trade-off.

### 5.3 Communication overhead

In this section, the communication overhead of log-in and authentication phase comparison is prepared with respect to other existing schemes as these phases are frequently used rather than registration and password change phase. The communication overhead is considered as mentioned by Wajid et al. [9], i.e., selecting long identity of the user as 160 bits, identity of the nodes as 32 bits, any random nonce as 128 bits, modular exponentiation as 512 bits, time stamp length as 32 bits, ECC-based public/private keys as 160 bits and symmetric encryption and decryption block as 160 bits and ECC points is 320 bits.

In the authentication and key agreement phase 1 message is communicated each from Msg1: user to gateway, *Msg 2*: IoT node to gateway, *Msg 3*: gateway to IoT node and *Msg 4*: IoT node to gateway. *Msg 1* contains $ID_U$, $E_{K_X}(H_U \parallel R_U), T_1$ that incurs cost of $160+160+32 = 352$, *Msg 2* contains $ID_N$, $E_{L_X}(H_N \parallel R_N)\}$, $\{ID_U, E_{K_X}(H_U \parallel R_U)\}T_2$ incurs cost of $32+160+160+32=384$, *Msg 3* contains $\{ID_G, E_{L_X}(H_U \parallel R_U)\}$, $\{ID_N, ID_G, E_{K_X}(H_N \parallel R_N)\}$ incurs cost of $160+160+32+160+160=512$, *Msg 4* contains $ID_N$, $ID_G$, $E_{K_X}(H_N \parallel R_N)$ incurs cost of $32+160+160=384$.

According to the above-mentioned considerations, the scheme surpasses the relevant of the schemes. The comparison is demonstrated separately for user, IoT node, and gateway in Table 4, and it clearly reveals that the proposed scheme provides minimum communication overhead that makes the scheme efficient for IoT environment.

**Table 5** Comparison of communication overhead for authentication with existing schemes [8–10, 25, 26, 30, 31, 36]

| Authentication scheme | No of message communicated | Communication costs (No of bits transmitted) | | | |
|---|---|---|---|---|---|
| | | User | IoT_node | Gateway | Total |
| Poorambage et al. [25] | 4 | 768 | 768 | 1824 | 3360 |
| Turkanovic et al. [26] | 4 | 672 | 576 | 1472 | 2720 |
| Das et al. [10] | 4 | 512 | 384 | 1088 | 1984 |
| Cheng and Le [30] | 4 | 672 | 512 | 1088 | 2272 |
| Jiang et al. [8] | 4 | 512 | 1056 | 384 | 1952 |
| Dhillon and Karla [31] | 4 | 992 | 512 | 1024 | 2528 |
| Challa et al. [33] | 3 | 992 | 512 | 1024 | 2528 |
| Wazid et al. [9] | 4 | 736 | 512 | 1344 | 2592 |
| Shuai et al. [36] | 4 | 864 | 544 | 960 | 2368 |
| Fakroon et al. [34] | 4 | 800 | 416 | 1088 | 2304 |
| Proposed scheme | 4 | 320 | 384+384 | 512 | 1600 |

### 5.4 Storage consumption overhead

The memory overhead of the proposed scheme is significantly less than other existing scheme as in this scheme the user's smart device needs not to store much information about the communication.

In the proposed scheme, the user stores a hash digest $H_U$, and a random ECC point $R_U$ in their device memory, and the sensor node stores identity $ID_N$ and random ECC point $R_N$. According to consideration mentioned in subsection 5.3 the total storage space required by the user is $160 + 320$ bits, i.e., 480bits and the sensor node requires $32 + 320$ bits, i.e., 356 bits.

Table 5 demonstrates the comparison of the storage overhead of the proposed scheme and the other related scheme [9, 10, 17, 31, 34]. It is clearly visible that the proposed scheme requires much less storage consumption in compared to others. Although our scheme maintains "sensor-node- first–contact-approach" [17], it does not need to carry any extra burden for the IoT nodes. Thus, this scheme is more flexible for ensuring more lifetimes of the IoT nodes by reducing the storage utilization.

## 6 Formal security verification using AVISPA

The Automated Verification Internet Security Protocol and Analysis (AVISPA) is a push button simulation tool for formal security evaluations of security protocols to detect whether those are SAFE or UNSAFE against various active and passive security attacks in a real-time working environment and supports High-Level Protocol Specification Language (HLPSL) [31, 52–55]. HLPSL is a communicative language for defining secured transitions and modular specification of the protocols [42]. The HLPSL code is automatically translated into an independent intermediate format IF by HLPSL2IF translator to input it to the backends of AVISPA for automatic analysis of user specified protocol. The four backends

**Table 6** Comparison of storage overhead for authentication with existing schemes [9, 10, 17, 20, 26, 31, 34]

| Authentication schemes | Smart card/device storage cost (bits) | Sensor node storage cost (bits) |
|---|---|---|
| Turkanovic et al. [26] 2014 | 768 | 512 |
| Das et al. [10] 2015 | 768 + CH* | – |
| Dhillon and Karla [31] 2017 | 640 | 512 |
| Wazid et al. [9] 2018 | 576 | 512 |
| Fakroon et al. [34] 2020 | 704 | 1056 |
| Proposed scheme | 480 | 356 |

integrated through HLSPL are (1) *On- The-Fly-Model-Checker* (*OFMC*): It provides a tree-based symbolic technique for state-space search in a demand-driven way for ensuring the correctness of the specified protocol for a limited number of sessions.(2) *Constraint-Logic- based Attack Searcher* (*CL- AtSe*): Using a set of constraints obtained from IF this backend detects attacks based on adversary knowledge of the specified protocol. (3) *State-of-the-Art Solver* (*SAT*): It generates propositional formulae and detects attacks in the protocol. (4) *Tree Automata based on Automate Approximation for Analysis of Security Protocol* (*TA4SP*): This backend discovers approximation of intruder knowledge using regular tree based language [52].

AVISPA is a role-oriented language where each participant accomplices an independent key role for execution of the specified protocol. Initially, parameters

```
role user(U,N,GW      : agent,
          KA,KB       :symmetric_key,
          % H is hash function
          H,MUL    : hash,
          Snd,Rcv : channel(dy))
played_by U
def=
local State : nat,
DU,VU,UN,IDU,IDN,IDG,RAA,P,VG       : text,
MU,HU,BU,PU,RU,RGU,RN,SKA,K   : message,
Inc: hash
const  user_gateway,gateway_iot,user_iot,subs1,subs2,subs3,subs4,subs5,subs6: protocol_id
init State := 0
transition
1. State =0 /\Rcv (start)=|>
   State' := 1 /\ DU'=new()
   /\ VU' := MUL (DU'.P)
   /\ KA ':=MUL(DU.VG)
   /\ RAA' := new()
   /\ RU':= MUL(RAA'.P)
   /\ Snd(IDU,{IDU.RU'}_KA')
   /\ secret({DU'},subs1,{U})
2. State =1/\ Rcv(IDG,{RU'.RGU'}_KA)=|>
   State':=2/\ HU':= H(IDU.PU.BU)
   /\ MU':= H(HU.RU.RGU)
   /\ Snd(IDU,{RU.MU}_KA')
   /\ secret({RU'},subs4,{U,GW})
3. State =2/\ Snd(IDU,{HU.RU}_KA')=|>
    State'=3
4.  State =3/\ Rcv(IDN,IDG,{IDN.RN}_KA')=|>
    State':=4
   /\ SKA' = MUL(RAA'.RN)
end role
```

**Fig. 9** User role specification of the proposed scheme using

```
role iot (N,GW,U      : agent,
          KA,KB       :symmetric_key,
          % H is hash function
          H,MUL    : hash,
          Snd,Rcv  : channel(dy))
played_by N
def=
local State : nat,
VU,IDU,IDN,IDG,RBB,P,VG:text,
HU,HN,MN,PN,RN,RU,RGN,SKA,X:message,
Inc: hash
const user_gateway,gateway_iot,user_iot,subs1,subs2,subs3,subs4,subs5,subs6: protocol_id
init State :=0
transition
1. State = 0 /\ Rcv (start)=|>
    State' :=1
   /\ KB' := MUL(X.VG)
   /\ RBB' := new()
   /\ RN' :=MUL(RBB'.P)
   /\ Snd(IDN,{IDN.RN'}_KB')
   /\ secret ({X'},subs2,{N,GW})
2. State = 1 /\ Rcv (IDG,{RN.RGN}_KB') =|>
   State' :=2
   /\ HN' := H(IDN,RN)
   /\ MN' := H(HN'.RN'.RGN')
   /\ Snd(IDN,{RN'.MN'}_KB')
   /\ secret({RN'},subs5,{N,GW})
3. State = 2  /\ Rcv (IDU,{HU.RU}_KA')=|>
   State' := 3 /\ HN'=H(IDN.RN)
   /\  Snd(IDN,{HN.RN}_KB')
   /\  Snd(IDU,{HU.RU}_KA')
4. State = 3 /\ Rcv (IDG,{IDU.RU}_KB)/\ Rcv (IDN,IDG,{IDN.RN}_KA)=|>
   State' := 4
   /\ SKA'= MUL(RBB'.RU)
   /\ Snd(IDN,IDG,{IDN.RN}_KA')
    end role
```

**Fig. 10** IoT_node role specification of the proposed scheme using AVISPA

of each role are specified using arguments such as agents, keys, algebraic operators and communication channels in between different roles. Additionally, the intruder knowledge is also modeled using assumptions that an intruder may know some parameters and hence plays a legitimate role in the protocol. In session role, all the basic roles are instanced in the role session with actual arguments where

```
role gateway(GW,U,N  : agent,
             KA,KB   :symmetric_key,
          % H is hash function
          H,MUL   : hash,
          Snd,Rcv  : channel(dy) )
played_by GW
def=
local State : nat,
DS,VU,VG,IDU,IDN,IDG,P,US,RGG,RNN:text,
MU,HN,HU,MN,RN,RU,X,RGU,RGN,KAA,KBB:message,
Inc : hash
const user_gateway,gateway_iot,user_iot,subs1,subs2,subs3,subs4,subs5,subs6:protocol_id
init State := 0
transition
1. State = 0 /\ Rcv(IDU,{IDU.RU'}_KA')=|>
   State' = 1 /\ VG'= MUL(DS.P)
   /\ KA'= MUL(DS.VU)
   /\ RGG':= new()
   /\ RGU' := MUL(RGG'.P)
   /\ Snd(IDG,{RU'.RGU'}_KA)
   /\secret({RGU},subs3,{GW,U})
   /\ secret({DS},subs6,{GW})
2. State = 1 /\ Rcv(IDU,{RU.MU}_KA')=|>
   State'=2
3. State = 2 /\ Rcv (IDN,{IDN.RN'}_KB') =|>
   State':= 3 /\ KB'= MUL(DS.X.P)
   /\ RNN'=new()
   /\ RGN'= MUL(RNN'.P)
   /\Snd(IDG,{RN'.RGN'}_KB)
4. State =3 /\ Rcv(IDN,{RN'.MN'}_KB') =|>
   State':= 4
3. State = 4 /\ Rcv (IDN,{HN'.RN'}_KB')/\ Rcv(IDU,{HU'.RU'}_KA')=|>
   State':=5 /\ MN':= H(HN'.RN'.RGN')
   /\ MU':= H(HU'.RU'.RGU')
   /\Snd(IDG,{IDU.RU}_KB)
   /\Snd (IDN,IDG,{IDN.RN}_KA)
end role
```

**Fig. 11** Gateway role specification of the proposed scheme using AVISPA

as the environment role defines all compositions of all variables and global constants [58] (Table 6).

### 6.1 Specification of proposed protocol

This section describes all the basic and composite roles used in the implemented phases, i.e., registration phase, mutual authentication and session key negotiation phase of the proposed scheme using HLPSL. The basic roles user $U$, IoT node $N$ and

```
role session(U,N,GW  :agent,
             KA,KB    :symmetric_key,
             H,MUL : hash) %line 78
def=
local SI,SJ,RI,RJ,TI,TJ:channel(dy)
composition
user(U,GW,N,KA,KB,H,MUL,SI,RI)/\ gateway(U,GW,N,KA,KB,H,MUL,SJ,RJ)/\
iot(U,GW,N,KA,KB,H,MUL,TI,TJ)
end role
role environment()
def=
const u,n,gw:agent,
ka,kb          :symmetric_key,
h,mul : hash,
idu,idn,idg,vu,du,ru,rn,idu,idn,ru,rn,rgu,rgn,ds,vg,kaa,kbb,hu,hn,mu,mn,raa,rbb,rgg,rnn:text,
user_gateway,gateway_iot,user_iot,subs1,subs2,subs3,subs4,subs5,subs6:protocol_id
intruder_knowledge={u,n,gw,h,mul,ru,rn}
composition
session(u,n,gw,ka,kb,h,mul)
/\ session(gw,n,u,ka,kb,h,mul)
/\session(gw,n,u,ka,kb,h,mul)
end role
goal
secrecy_of subs1
secrecy_of subs2
secrecy_of subs3
secrecy_of subs4
secrecy_of subs5
secrecy_of subs6
authentication_on user_gateway_raa
authentication_on user_gateway_mu
authentication_on iot_gateway_rbb
authentication_on iot_gateway_mn

end goal
environment()
```

**Fig. 12** Session and environment role specification of the proposed scheme using AVISPA

gateway *GW* communicate using *Snd*() and *Rcv*() operations to transmit messages over *Dolev–Yao* (*dy*) channel. *P* is the generator point for the elliptic curve $E/F_q$. *KA*,*KB* are the contributory symmetric session keys between user and gateway and IoT node and gateway, respectively. The characteristics specified in 'Goal'section are illustrated as the main aims of the scheme. The code specification for the basic entities (user, IoT node, and gateway) and composite role (session and environment) is shown in Figs. 9, 10, 11 and 12, respectively.

```
% OFMC
% Version of 2006/02/13
SUMMARY
 SAFE
DETAILS
 BOUNDED_NUMBER_OF_SESSIONS
PROTOCOL
 /home/span/span/testsuite/results/iot_gateway.if
GOAL
 as_specified
BACKEND
 OFMC
COMMENTS
STATISTICS
 parseTime: 0.00s
 searchTime: 0.79s
 visitedNodes: 469 nodes
 depth: 9 plies
```

**Fig. 13** Result analysis of the proposed scheme using OFMC backend of AVISPA

```
SUMMARY
 SAFE

DETAILS
 BOUNDED_NUMBER_OF_SESSIONS
 TYPED_MODEL

PROTOCOL
 /home/span/span/testsuite/results/iot_gateway.if

GOAL
 As Specified

BACKEND
 CL-AtSe

STATISTICS
```

**Fig. 14** Result analysis of the proposed scheme using CL-AtSe backend of AVISPA

The main goals of the scheme are to maintain the secrecy of some parameters used in the scheme and to authenticate the remote user and the IoT node through gateway. This goals specified in HLPSL are as follows

- secrecy_of subs1: It represents that the private key of agent *U* (user) must be kept secret to user *U* only.
- secrecy_of subs2: It represents that the pre-secret key of agent *N* (IoT Node) must be kept secret to the node *N* only.
- secrecy_of subs3: It represents that the private key of agent *GW* (gateway) must be kept secret to gateway *GW only*.
- secrecy_of subs4: It represents that the random point of user must be known to user and gateway only.
- secrecy_of subs5: It represents that the random point of IoT node must be known to itself and gateway only.

- authentication_on user_gateway_raa: It means that *U* generates a random no *RAA*, and gateway receives it in the form of a point *RU* as a message securely then *GW* authenticates *U*.
- authentication_on iot_gateway_rbb: It means that *N* generates a random no *RBB*, and gateway receives it in the form of a point as a message securely then *GW* authenticates *N*.
- authentication_on user_gateway_mu: It means user *U* must be authenticated on the basis of parameter MU by the gateway.
- authentication_on iot_gateway_mn: It means IoT node *N* must be authenticated on the basis of parameter *MN* by the gateway.

### 6.2 Simulation result

All the protocols of our scheme are simulated using AVISPA tool and it is found that all are safe against any passive and active attacks. In this section, the simulation result of registration, and mutual authentication and session key negotiation protocol on the backends *OFMC* and *CL-AtSe* is shown in Figs. 13 and 14 that illustrate that the proposed protocols are *SAFE* in the two backends (OFMC and CL-AtSe). Thus, it ensures that the proposed scheme is not vulnerable against any passive and active attacks, and hence, it can be claimed that the proposed scheme is safe and well-protected.

## 7 Conclusion

Security and resource efficiency are the two most important hindrance of large scale application of any authentication scheme in the IoT network. It is hard to find any robust scheme appropriate for implementation in IoT network. As a step towards to right direction we have proposed a three-factor ECC-based lightweight remote user authentication scheme for IoT network. The proposed scheme provides legal mutual authentication between user and IoT_ node through gateway and by the end an ECDH-based secure session key is established between user and IoT node for further data communication without the intervention of the gateway. The security analysis and formal verification of the scheme using AVISPA tool is performed that proves the safety strength of the scheme. Performance analysis demonstrates that the scheme is lightweight compared to previous related schemes. In addition the scheme also supports symmetric key and password update phase. Thus, security performance trade-off and other additional functionalities make the scheme suitable for practical implementation.

## References


1. Ahmed MR, Huang X, Sharma D, Cui H (2012) Wireless sensor network: characteristics and architectures. Int J Electr Comput Energ Electron Commun Eng 6(12):1398–1401
2. Henze M, Hermerschmidt L, Kerpen D, Häußling R, Rumpe B, Wehrle K (2016) A comprehensive approach to privacy in the cloud-based Internet of Things. Future Gener Comput Syst 56:701–718
3. Jing Q, Vasilakos VA, Wan J, Lu J, Qiu D (2014) Security of the Internet of Things: perspectives and challenges. Wirel Netw 20(8):2481–2501
4. Li L (2012) Study on security architecture in the Internet of Things. In: 2012 International Conference on Measurement, Information and Control (MIC), vol 1. IEEE, pp 374–377
5. Wu F, Xu L, Kumari S, Li X, Shen J, Choo KKR, Das AK (2017) An efficient authentication and key agreement scheme for multi-gateway wireless sensor networks in IoT deployment. J Netw Comput Appl 89:72–85
6. Amin R, Kumar N, Biswas GP, Iqbal R, Chang RV (2018) A light weight authentication protocol for IoT-enabled devices in distributed Cloud Computing environment. Future Gener Comput Syst 78:1005–1019
7. Atzori L, Iera A, Morabito G (2010) The internet of things: a survey. Comput Netw 54(15):2787–2805
8. Jiang Q, Wei F, Fu S, Ma J, Li G, Alelaiwi A (2016) Robust extended chaotic maps-based three-factor authentication scheme preserving biometric template privacy. Nonlinear Dyn 83(4):2085–2101
9. Wazid M, Das AK, Odelu V, Kumar N, Conti M, Jo M (2018) Design of secure user authenticated key management protocol for generic iot networks. IEEE Internet of Things J 5(1):269–282
10. Das AK, Goswami A (2015) A robust anonymous biometric-based remote user authentication scheme using smart cards. J King Saud Univ Comput Inf Sci 27(2):193–210
11. Kumari S, Li X, Wu F, Das AK, Arshad H, Khan MK (2016) A user friendly mutual authentication and key agreement scheme for wireless sensor networks using chaotic maps. Future Gener Comput Syst 63:56–75
12. Souissi I, Azzouna NB, Said LB (2019) A multi-level study of information trust models in WSN-assisted IoT. Comput Netw 151:12–30
13. Weber RH (2010) Internet of Things-New security and privacy challenges. Comput Law Secur Rev 26(1):23–30
14. Gubbi J, Buyya R, Marusic S, Palaniswami M (2013) Internet of Things (IoT): a vision, architectural elements, and future directions. Future Gener Comput Syst 29(7):1645–1660
15. Chang E, Thomson P, Dillon T, Hussain F (2005) The fuzzy and dynamic nature of trust. In: International Conference on Trust, Privacy and Security in Digital Business. Springer, Berlin, pp 161–174
16. Yan Z, Zhang P, Vasilakos AV (2014) A survey on trust management for Internet of Things. J Netw Comput Appl 42:120–134
17. Xue K, Ma C, Hong P, Ding R (2013) A temporal-credential-based mutual authentication and key agreement scheme for wireless sensor networks. J Netw Comput Appl 36(1):316–323
18. Wang D, Zhang X, Zhang Z, Wang P (2020) Understanding security failures of multi-factor authentication schemes for multi-server environments. Comput Secur 88:101619
19. Sood SK, Sarje AK, Singh K (2010) An improvement of Wang et al.'s authentication scheme using smart cards. In: 2010 National Conference on Communications (NCC). IEEE, pp 1–5
20. Song R (2010) Advanced smart card based password authentication protocol. Comput Standards Interfaces 32(5–6):321–325
21. Chen TH, Hsiang HC, Shih WK (2011) Security enhancement on an improvement on two remote user authentication schemes using smart cards. Future Gener Comput Syst 27(4):377–380
22. Kumari S, Khan MK (2014) Cryptanalysis and improvement of 'a robust smart-card-based remote user password authentication scheme'. Int J Commun Syst 27(12):3939–3955
23. Mishra D, Das AK, Chaturvedi A, Mukhopadhyay S (2015) A secure password-based authentication and key agreement scheme using smart cards. J Inf Secur Appl 23:28–43
24. Sharma G, Kalra S (2018) A lightweight multi-factor secure smart card based remote user authentication scheme for cloud-IoT applications. J Inf Secur Appl 42:95–106
25. Porambage QP, Schmitt C, Kumar P, Gurtov A, Ylianttila M (2014) Two-phase authentication protocol for wireless sensor networks in distributed IoT applications. In: Proceedings of IEEE Wireless Communications and Networking Conference (WCNC), Istanbul, Turkey, pp 2728–2733

26. Turkanović M, Brumen B, Hölbl M (2014) A novel user authentication and key agreement scheme for heterogeneous ad hoc wireless sensor networks, based on the Internet of Things notion. Ad Hoc Netw 20:96–112
27. Amin R, Biswas GP (2016) A secure light weight scheme for user authentication and key agreement in multi-gateway based wireless sensor networks. Ad Hoc Netw 36:58–80
28. Kalra S, Sood SK (2015) Secure authentication scheme for IoT and cloud servers. Pervasive Mob Comput 24:210–223
29. Kumari S, Karuppiah M, Das AK, Li X, Wu F, Kumar N (2018) A secure authentication scheme based on elliptic curve cryptography for IoT and cloud servers. J Supercomput 74(12):6428–6453
30. Chang C-C, Le H-D (2016) A provably secure, efficient, and flexible authentication scheme for ad hoc wireless sensor networks. IEEE Trans Wirel Commun 15(1):357–366
31. Dhillon PK, Kalra S (2017) A lightweight biometrics based remote user authentication scheme for IoT services. J Inf Secur Appl 34:255–270
32. Souri A, Norouzi M (2019) A state-of-the-art survey on formal verification of the internet of things applications. J Serv Sci Res 11(1):47–67
33. Challa S, Wazid M, Das AK, Kumar N, Reddy AG, Yoon EJ, Yoo KY (2017) Secure signature-based authenticated key establishment scheme for future IoT applications. IEEE Access 5:3028–3043
34. Fakroon M, Alshahrani M, Gebali F, Traore I (2020) Secure remote anonymous user authentication scheme for smart home environment. Internet of Things, p 100158
35. Hussain K, Jhanjhi NZ, Mati-ur-Rahman H, Hussain J, Islam MH (2019) Using a systematic framework to critically analyze proposed smart card based two factor authentication schemes. J King Saud Univ Comput Inf Sci 2019
36. Shuai M, Yu N, Wang H, Xiong L (2019) Anonymous authentication scheme for smart home environment with provable security. Comput Secur 86:132–146
37. Hankerson D, Menezes AJ, Vanstone S (2006) Guide to elliptic curve cryptography. Springer, Berlin
38. Kapoor V, Abraham VS, Singh R (2008) Elliptic curve cryptography. Ubiquity 20:7
39. Koblitz N (2000) Towards a quarter-century of public key cryptography. Kluwer Academic, Dordrecht
40. Miller VS (1985) Use of elliptic curves in cryptography. In: Conference on the Theory and Application of Cryptographic Techniques. Springer, Berlin, pp 417–426
41. Stallings W (2006) Cryptography and network security: principles and practices. Pearson Education India
42. Ray S, Biswas GP (2012) Establishment of ECC-based initial secrecy usable for IKE implementation. In: Proceedings of World Congress on Expert Systems (WCE)
43. Ray S, Biswas GP (2011) Design of mobile-PKI for using mobile phones in various applications. In: 2011 International Conference on Recent Trends in Information Systems (ReTIS). IEEE, pp 297–302
44. Ray S, Biswas GP (2012) An ECC based public key infrastructure usable for mobile applications. In: Proceedings of the Second International Conference on Computational Science, Engineering and Information Technology. ACM, pp 562–568
45. Ray S, Biswas GP, Dasgupta M (2016) Secure multi-purpose mobile-banking using elliptic curve cryptography. Wirel Pers Commun 90(3):1331–1354
46. Paar C, Pelzl J (2009) Understanding cryptography: a textbook for students and practitioners. Springer, Berlin
47. Guajardo J, Paar C (1997) Efficient algorithms for elliptic curve cryptosystems. In: Annual International Cryptology Conference. Springer, Berlin, pp 342–356
48. Moon AH, Iqbal U, Bhat GM (2016) Mutual entity authentication protocol based on ECDSA for WSN. Proc Comput Sci 89:187–192
49. Lynn B (2007) On the implementation of pairing-based cryptosystems (Doctoral dissertation, Stanford University)
50. Kilinc HH, Yanik T (2014) A survey of SIP authentication and key agreement schemes. IEEE Commun Surv Tutor 16(2):1005–1023
51. He D, Gao Y, Chan S, Chen C, Bu J (2010) An enhanced two-factor user authentication scheme in wireless sensor networks. Ad hoc Sens Wirel Netw. 10(4):361–371
52. Hernández-Ramos JL, Moreno MV, Bernabé JB, Carrillo DG, Skarmeta AF (2015) SAFIR: secure access framework for IoT-enabled services on smart buildings. J Comput Syst Sci 81(8):1452–1463

53. Viganò L (2006) Automated security protocol analysis with the AVISPA tool. Electron Notes Theor Comput Sci 155:61–86
54. Reddy G, Das AK, Yoon E, Yoo K (2016) A secure anonymous authentication protocol for mobile services on elliptic curve cryptography. IEEE Access 4:4394–4407
55. Islam SKH, Amin R, Biswas GP, Farash MS, Li X, Kumari S (2017) An improved three party authenticated key exchange protocol using hash function and elliptic curve cryptography for mobile-commerce environments. J King Saud Univ Comput Inf Sci 29(3):311–324

**Publisher's Note** Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

## Affiliations

**Dipanwita Sadhukhan[1] · Sangram Ray[1] · G. P. Biswas[2] · M. K. Khan[3] · Mou Dasgupta[4]**

Dipanwita Sadhukhan
dipanwitasadhukhan2012@gmail.com

G. P. Biswas
gpbiswas@gmail.com

M. K. Khan
mkhurram@ksu.edu.sa

Mou Dasgupta
elle.est.mou@gmail.com

[1] Department of Computer Science and Engineering, National Institute of Technology Sikkim, Ravangla 737139, India

[2] Department of Computer Science and Engineering, Indian Institute of Technology (ISM), Dhanbad, Jharkhand 826004, India

[3] Center of Excellence in Information Assurance, King Saud University, Riyadh 11653, Kingdom of Saudi Arabia

[4] Department of Computer Application, National Institute of Technology Raipur, Raipur 492010, India